

單元 9 · 健康科技研究方法 · Research Methodology

資料隱私、資安與數位健康倫理

Privacy, Security & Digital Ethics — 用得了健康資料，更要用得正當、安全、可信

涵蓋：研究倫理(Belmont) · HIPAA/GDPR/個資法 · 去識別化 · 資安 CIA · 二次利用 · 演算法公平 · 資料治理

實例：一個穿戴式資料研究平台，從知情同意到去識別、資安與二次利用的倫理把關

增修單元 7.1 研究倫理 + 新增數位健康倫理 · 對應：Belmont / HIPAA / GDPR / 個資法 · S2

課程地圖 Course Map

從『研究倫理基礎』一路走到『數位時代的新倫理課題』

部分	主題	你會學到
Part 1	研究倫理基礎	Belmont 三原則、知情同意、IRB (增修單元 7.1)
Part 2	隱私與法規	隱私原則、HIPAA、GDPR、台灣個資法 (2025 新制)
Part 3	去識別化與技術	匿名 vs 假名、Safe Harbor、再識別風險、差分隱私
Part 4	資安 Security	CIA 三要素、威脅、防護、資料外洩應變
Part 5	數位健康倫理	二次利用、演算法公平、公平近用、資料治理 + 實例

教學重點 一句話抓重點：健康資料既『極度敏感』又『極度有價值』——這個張力，讓隱私、資安與倫理在健康科技裡分不開。這一課先補強研究倫理的基礎 (增修單元 7.1)，再把它延伸到數位時代的新問題：大規模資料的二次利用、AI 的公平、去識別化的極限、以及資料治理。用得了資料，更要用得正當。

為什麼健康科技特別需要這一課？

健康資料一旦外洩或誤用，傷害無法復原

健康資料的特殊性

- 極度敏感：病史、基因、心理狀態...
 - 一旦外洩無法『收回』（不像換密碼）
 - 可能導致歧視（保險、就業）、污名
 - 可被『推論』：看似無害資料能推出敏感事實
- 傷害可能終生、不可逆

這一課給你的能力

- 用研究倫理三原則判斷『該不該、怎麼做』
 - 懂 HIPAA/GDPR/個資法的核心要求
 - 正確去識別化，並知道它的極限
 - 守住資安、面對數位時代的新倫理問題
- 讓資料被『正當、安全、可信』地使用

教學重點 定位：這一課『增修單元 7.1 研究倫理』並延伸到數位健康。它把整個單元 9 收束在『正當性』上——你有能力做出有效(9.4/9.5)、好用(9.7)、能上市(9.10)的產品，但『能不能、該不該用這些資料』是倫理與法律問題。健康資料的信任一旦崩壞，整個健康科技生態都會受害。這是技術之外，最不能忽略的一課。

1

PART 1

研究倫理基礎

Foundations of Research Ethics

增修單元 7.1 · 對應：Belmont

先補強研究倫理的地基：三大原則、知情同意、倫理審查。
再看數位時代如何挑戰這些傳統框架。

Belmont 三原則：研究倫理的地基

1979 年至今，仍是判斷『該不該、怎麼做』的準繩

原則	意思	實務對應
尊重人 Respect	尊重自主、保護弱勢	知情同意、自願參與、可退出
行善 Beneficence	最大化益處、最小化傷害	風險-效益評估、保護隱私
正義 Justice	公平分配研究的負擔與益處	公平選樣、勿只用弱勢當受試者

教學重點 為什麼從 Belmont 開始：它源於歷史上的研究醜聞（如未告知的人體實驗），提出三個至今適用的原則。① 尊重人→你不能未經同意就拿別人的資料做研究；② 行善→要權衡益處與傷害、保護隱私；③ 正義→研究的好處與風險要公平分配。數位健康的所有新問題，幾乎都能回到這三個原則來思考。

知情同意：不是簽個名，是一個過程

讓人在『充分理解』下，自願決定

有效同意的要素

- 充分告知：目的、做什麼、風險與益處
 - 理解：用對方懂的語言（非艱澀術語）
 - 自願：無脅迫、無不當誘因
 - 有能力：具同意能力（弱勢需特別保護）
 - 可隨時退出、不受懲罰
- 缺一都可能讓同意無效

數位帶來的難題

- 冗長條款沒人看 → 同意疲勞
 - 資料未來『二次利用』很難事先講清楚
 - 演算法推論出當事人沒同意的資訊
 - 匿名資料是否還需同意？
- 傳統『一次性同意』越來越不夠（見 P5）

教學重點 知情同意的精神是『自主』：讓人在真正理解的情況下自己決定。數位時代最大的挑戰是——資料常被『未來、以你當初想不到的方式』再利用。落長沒人讀的同意書，只是形式上的同意，不是真正的自主。Part 5 會談『廣泛同意、動態同意』等新做法來回應這個難題。

倫理審查(IRB/REC)：研究前的把關

獨立第三方，審你的研究倫理上站不站得住

IRB 在審什麼

- 風險-效益是否合理
 - 知情同意程序是否妥當
 - 隱私與資料保護措施
 - 弱勢族群是否受保護
 - 招募是否公平、無脅迫
- 通過才能開始收案

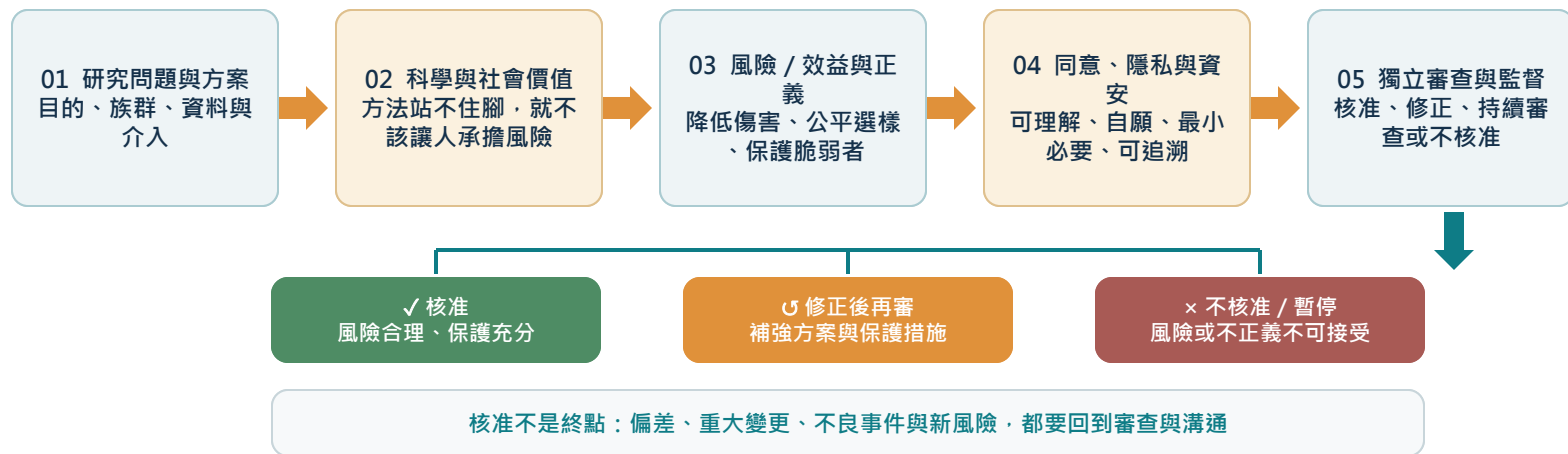
實務提醒

- 幾乎所有涉及『人』或『可識別資料』的研究都需送審
 - 用『既有資料/次級資料』也常需審查或核備
 - 跨國研究要符合各地規範
 - 這是投稿與發表的前提（接 1.3）
- 別做完才補，要事前送審

教學重點 IRB（倫理審查委員會）是研究誠信的第一道關卡：由獨立第三方在研究『開始前』審查它倫理上站不站得住。涉及人或可識別個資的研究幾乎都要送審——包括用既有健康資料庫的次級研究。這不只是行政程序，而是保護受試者、也保護你（讓研究經得起檢驗、能發表）的機制。務必事前送審，別做完才補。

研究倫理把關：從好問題走到可執行的研究

IRB/REC 的核心不是「蓋章」，而是把價值、風險、同意、公平與資料保護串成可監督的決策



依據：HHS Belmont Report；45 CFR 46 (Common Rule)

教學重點 倫理審查先問「研究值得做嗎、方法可靠嗎」，再問風險是否最小且合理、招募是否公平、同意與資料保護是否充分；核准後仍需持續監督。

2

PART 2

隱私與法規

Privacy Principles & the Law

對應：HIPAA · GDPR · 個資法

隱私不只是道德，也是法律。先掌握共通的隱私原則，
再認識三大體系：美國 HIPAA、歐盟 GDPR、台灣個資法。

共通的隱私原則：少拿、講清楚、只用在說好的用途

不管哪國法規，精神大同

原則	意思
目的限制	只為『說好的目的』蒐集與使用，不能偷偷他用
資料最小化	只拿『必要』的資料，不是能拿就拿
透明	告訴當事人你拿了什麼、要做什麼
當事人權利	可查詢、更正、刪除、拒絕、攜出
安全與當責	保護資料安全，並為此負責

教學重點 抓住精神就抓住大半：各國法規細節不同，但核心原則相通——① 只為說好的目的、② 只拿必要的、③ 講清楚、④ 尊重當事人的權利、⑤ 保護安全並當責。健康科技最常踩的雷是『資料最小化』與『目的限制』：先蒐集一大堆『以後可能有用』的資料、或把為 A 目的收的資料拿去做 B——這在多數法規下都有問題。

美國 HIPAA：保護『受保護健康資訊』(PHI)

兩大規則：隱私規則 + 資安規則

核心

- 保護 PHI (可識別的健康資訊)
 - 隱私規則：誰能用、揭露 PHI 的規範
 - 資安規則：電子 PHI 的安全防護要求
 - 適用『納管實體』(醫療院所、保險等) 及其『商業夥伴』
- 研究用 PHI 需同意或去識別

對研究/科技的意義

- 用 PHI 做研究：需 IRB 核准、同意，或『去識別化』(接 Part 3)
 - 去識別後的資料不受 HIPAA 限制
 - 違反有民事/刑事責任
 - 注意：很多健康 App 廠商『不』受 HIPAA 管
- 消費者資料保護有漏洞

教學重點 HIPAA 的範圍與盲點：它保護醫療體系內的『受保護健康資訊(PHI)』，規範誰能用、怎麼揭露，並要求電子資料的安全防護。但關鍵盲點是——它只管『納管實體』(醫院、保險等)，很多直接面向消費者的健康 App、穿戴裝置廠商『不』在 HIPAA 管轄內，你的健康資料保護反而有漏洞。用 PHI 做研究要嘛同意、要嘛去識別。

歐盟 GDPR：全球最嚴，健康資料是『特種資料』

合法基礎 + 特別保護 + 當事人強權利

核心

- 處理個資要有『合法基礎』（同意、法律義務...）
- 健康/基因資料屬『特種資料』：原則禁止，
例外（如明確同意、公共衛生）才可處理
- 高風險處理要做 DPIA（資料保護影響評估）
- 當事人權利強：查詢、更正、刪除（被遺忘權）、
可攜、拒絕自動化決策

對研究/科技的意義

- 研究有一定彈性，但仍需保障與最小化
 - 跨境傳輸有嚴格條件
 - 違反可罰全球營業額 4% 或 2000 萬歐元
 - 『被遺忘權』對 AI 訓練資料是挑戰
- 服務歐盟使用者就要遵循

教學重點 GDPR 是全球標竿：它要求任何個資處理都要有『合法基礎』，並把健康、基因資料列為『特種資料』（原則禁止處理，除非明確同意等例外）。高風險處理（如大規模健康 AI）要先做 DPIA。當事人有很強的權利，包括『被遺忘權』——這對已用資料訓練好的 AI 模型是真實挑戰。罰則極重（可達全球營收 4%），服務歐盟使用者就必須遵循。

台灣個資法：2025 大修，設『個資保護委員會』

本地最重要、也最新的發展

重點 (含 2025 新制)

- 個人資料保護法：規範蒐集、處理、利用
- 病歷、醫療、基因等屬『特種個資』，
原則禁止，例外 (同意、公益研究等) 才可
- 2025/11/11 公布修法 (施行日另定)：設立獨立的
『個人資料保護委員會(PDPC)』
- 強化外洩通報、監理與當事人保護

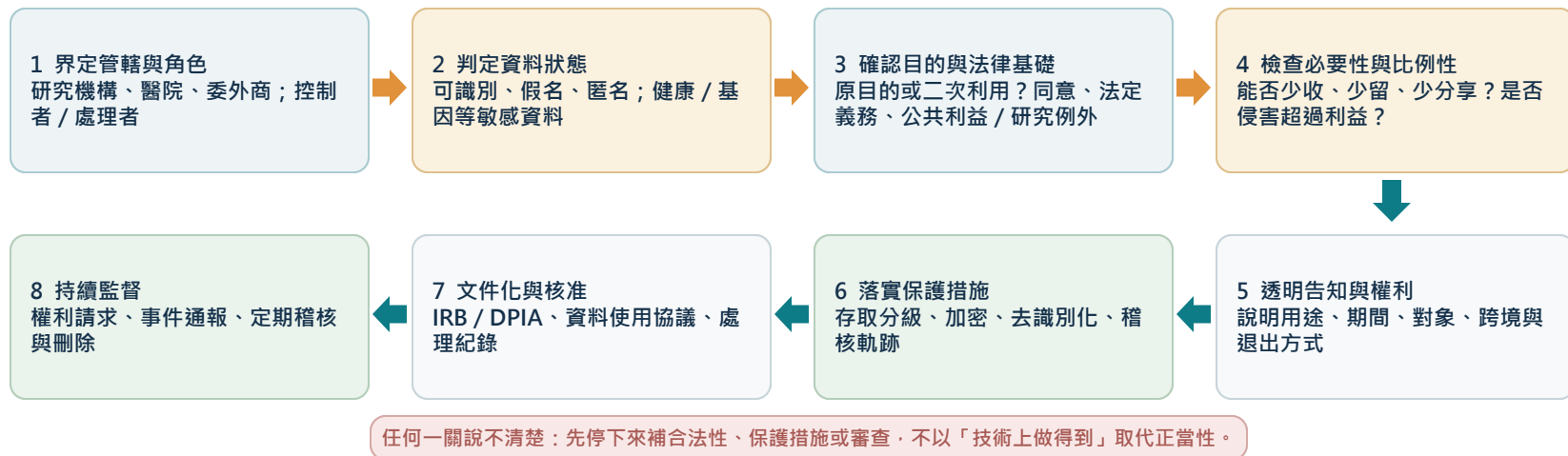
對研究/科技的意義

- 用醫療/健康個資需符合法定要件
 - 去識別後的利用仍要小心再識別風險
 - 外洩要依規定通報
 - 有獨立主管機關後，監理趨嚴
- 在台做健康資料研究務必follow最新規範

教學重點 在地最新動態：台灣個資法把病歷、醫療、基因等列為『特種個資』 (原則禁止蒐用，需符合例外)。2022 年憲法法庭要求設立獨立監理機關，催生了 2025 年 11 月公布的大幅修法——正式成立『個人資料保護委員會(PDPC)』，並強化外洩通報與監理。這代表台灣的個資監理將趨嚴、更接近國際標準。在台做健康資料研究，務必追蹤 PDPC 的最新規範。

使用健康資料前：八關決策流程

不同法域的條文不同，但合規思考都要回答「誰、什麼資料、為何、憑什麼、如何保護、如何負責」



依據：台灣個資法 (2025-11-11 修正) 第 3、5、6、8、12 條；GDPR；HHS HIPAA

教學重點 同意只是可能的法律基礎之一，也不會自動讓不必要或過度的處理變得正當；健康資料通常還要符合額外條件、透明義務與安全維護。

3

PART 3

去識別化與隱私技術

De-identification & Privacy Tech

對應：Safe Harbor · k-匿名 · 差分隱私

『去掉名字就安全了』其實是迷思。這一部教你去識別的方法、它的極限（再識別風險），以及進階的隱私保護技術。

匿名 vs 假名：差很多，別搞混

一個能還原、一個（理論上）不能

假名化 Pseudonymisation

- 把識別欄位換成代碼（如病歷號→編號）
 - 有『對照表』可以還原回本人
 - 對照表另存、嚴管
 - 在 GDPR 下『仍是個資』（可還原）
- 降低風險，但不是匿名

匿名化 Anonymisation

- 移除/擾動到『無法合理再識別』
 - 理論上無法還原回本人
 - 真正匿名的資料才脫離個資法規範
 - 但『真正匿名』極難（見再識別）
- 門檻比多數人以為的高很多

教學重點 最常見的誤解：很多人以為『把名字拿掉 = 匿名』。其實那多半只是『假名化』——只要有對照表或能透過其他欄位拼回去，它在法律上仍是個資。真正的『匿名化』要做到『無法合理再識別』，門檻高得多。這個區別很重要：假名資料仍受個資法保護，匿名資料才脫離規範——但要達到真匿名並不容易。

HIPAA 的兩種去識別法：規則 vs 風險

Safe Harbor 與專家判定

Safe Harbor (規則法)

- 移除『18 類識別碼』：姓名、地址細節、所有日期 (到年)、電話、病歷號、生物辨識特徵、臉部影像...
- 且『無實際知悉』仍可識別
- 照做即可，簡單明確
- 但可能移除太多、資料變粗

專家判定 (風險法)

- 由合格專家用統計方法評估
 - 確認『再識別風險非常小』
 - 可保留較多有用資訊
 - 需保存專家報告 (方法、假設、風險)
- 較彈性，但需專業與文件

教學重點 兩種思路：Safe Harbor 是『規則法』——把 18 類識別碼 (含姓名、細到區域的地址、所有日期、病歷號、臉部影像等) 通通拿掉，簡單但常把有用資訊也砍掉。專家判定是『風險法』——請合格專家用統計評估『再識別風險是否非常小』，能保留較多資訊但需專業與完整文件。健康資料研究常在『可用性』與『隱私』間用這兩法權衡。

再識別風險：『匿名』資料常沒你以為的安全

少數幾個欄位，就能拼回一個人

為什麼會被拼回來

- 研究顯示：光靠『生日+性別+郵遞區號』就能識別大部分人
 - 和外部資料庫『連結』就能還原
 - 罕見特徵（罕病、極端值）特別容易被指認
 - 軌跡/時序資料（定位、就醫）高度獨特
- 移除姓名遠遠不夠

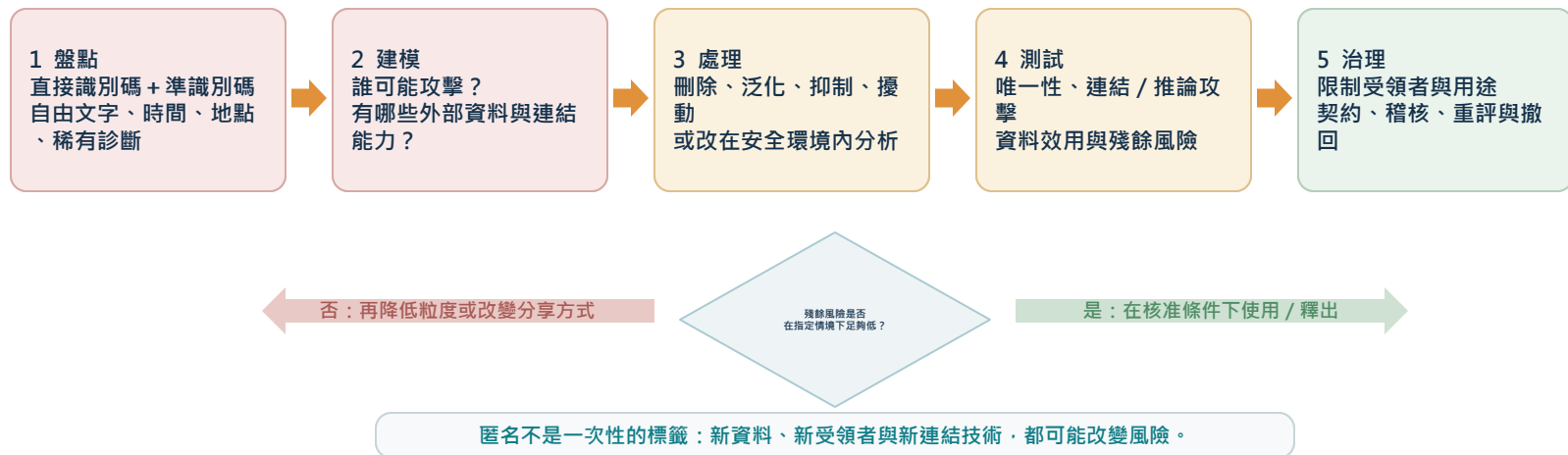
降低風險的做法

- k-匿名：每種屬性組合至少 k 人一樣（讓你藏在人群中）
 - l-多樣：每群的敏感值要夠多樣
 - 一般化/抑制：年齡→年齡層、模糊細節
 - 限制資料連結與存取
- 在可用與隱私間取捨

教學重點 殘酷的事實：『去識別』不是一勞永逸的保證。經典研究發現，光靠生日、性別、郵遞區號三個欄位，就能識別出美國大多數人；軌跡、就醫時序等資料更是獨特得像指紋。k-匿名（讓每種組合至少 k 人相同）、一般化（年齡→年齡層）能降低風險，但要在『資料還有沒有用』與『隱私』間取捨。永遠要評估『再識別風險』，而非假設匿名就安全。

再識別風險評估：資料、攻擊者與使用情境要一起看

「拿掉姓名」不等於匿名；外部資料、稀有組合、自由文字與受領者能力都會改變風險



依據：HHS HIPAA De-identification Guidance ; European Commission GDPR guidance

教學重點 去識別化是風險管理流程，不是一次性的欄位刪除。評估要納入預期受領者、可合理取得的外部資料、攻擊方式與實際使用環境。

進階技術：差分隱私與聯邦學習

讓你『用得到資料的價值，卻碰不到個人』

差分隱私 Differential Privacy

- 在結果/查詢中加入『數學上可控的雜訊』
- 保證：有沒有你這筆資料，結果幾乎一樣
 - 無法反推個人
- 可量化『隱私預算』
- 被大型科技公司、普查採用
 - 強的數學隱私保證

聯邦學習 Federated Learning

- 資料『不出醫院』，只交換模型參數
 - 在各院本地訓練，中央整合
 - 降低集中儲存的外洩風險
 - 常與差分隱私、加密結合
- 跨機構合作又保護隱私 (接 9.5)

教學重點 隱私增強技術(PETs)是趨勢：差分隱私用『可控的數學雜訊』保證『看不出你在不在資料裡』；聯邦學習讓『資料留在各醫院、只交換模型』，避免把敏感資料集中一處。兩者常結合使用。這些技術讓『善用健康資料的價值』與『保護個人隱私』不再是零和——是健康 AI (接 9.5) 跨機構合作的重要方向，但仍需搭配治理與同意。

依資料流選擇隱私強化技術 (PETs)

先決定資料是否必須移動、要交付什麼輸出，再選差分隱私、聯邦學習、安全環境或去識別化

使用需求	資料流設計	適合技術	仍要管理的風險
跨院訓練模型	資料留在原場域	聯邦學習 + 安全聚合	仍要防模型 / 更新洩漏；驗證各院資料偏差
讓研究者查詢	不交付原始資料	可信研究環境 / 資料安全區	限制輸出、審核查詢、完整稽核
發布統計結果	控制個人對輸出的影響	差分隱私	設定隱私預算 ϵ ；精度與隱私有取捨
分享列級資料	需保留分析價值	去識別化 + 專家風險評估	結合受領者、契約與使用環境控制

共同底座：加密、最小權限、用途限制、資料品質、攻擊測試、事件應變與可稽核性

依據：NIST Privacy Framework；HHS HIPAA De-identification Guidance

教學重點 PETs 不是魔法盾牌。每種技術都轉換風險，而非消除責任；仍需合法性、資料品質、存取控制、攻擊測試、稽核與事件應變。

4

PART 4

資安 Security

Securing Health Data

對應：CIA 三要素・外洩應變

隱私（該不該用）與資安（有沒有守好）是兩回事，但缺一不可。
再好的同意與去識別，資料被駭走一樣是災難。

資安的 CIA 三要素：機密、完整、可用

健康資料三者都要顧

要素	意思	健康情境的威脅
機密性 Confidentiality	只有被授權者能看	病歷外洩、被偷看
完整性 Integrity	資料不被竄改、正確	檢驗值被改、勒索軟體加密
可用性 Availability	需要時取用得到	系統被癱瘓 → 影響病人照護

教學重點 資安 ≠ 隱私：隱私問『該不該用、誰能用』，資安問『有沒有防止未授權存取與破壞』。CIA 三要素在醫療都攸關人命——機密性（病歷外洩傷害病人）、完整性（檢驗值被竄改會誤診）、可用性（系統被勒索軟體癱瘓，急診就停擺）。健康科技尤其要注意『可用性』：資安事件不只是資料外洩，還可能直接中斷照護。

威脅與防護：健康資料是駭客的高價目標

黑市上，病歷比信用卡還值錢

常見威脅

- 資料外洩 (外部入侵或內部人員)
 - 勒索軟體：加密系統勒索贖金
 - 釣魚、帳號被盜
 - 軟體醫材被攻擊 (接 9.10)
 - 第三方/供應鏈漏洞
- 醫療是攻擊熱點

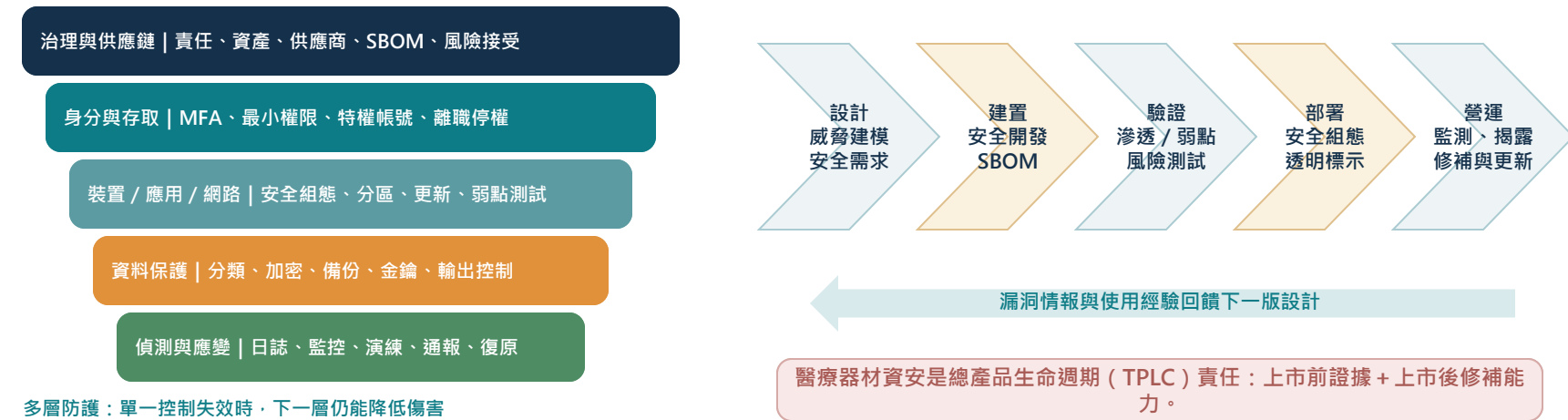
防護措施

- 存取控制：最小權限、多因素認證
 - 加密：傳輸中與儲存時都加密
 - 稽核日誌：誰在何時存取了什麼
 - 資料最小化：不留不必要的資料
 - 員工訓練、事故演練、備份
- 技術 + 管理 + 人，三管齊下

教學重點 為什麼醫療是重災區：健康資料在黑市價值高 (可用於詐騙、勒索、身分盜用)，且醫療機構系統常老舊、難停機更新。防護要『技術 + 管理 + 人』三管齊下：最小權限與多因素認證、傳輸與儲存都加密、稽核日誌可追溯、只留必要資料、加上員工訓練與事故演練。資安不是 IT 一個部門的事，是整個組織的責任。

縱深防禦 × 醫療器材全生命週期資安

安全不是一個工具，而是治理、身分、系統、資料與應變的多層控制，從設計一路延伸到上市後修補



依據：FDA 2026 Cybersecurity in Medical Devices guidance ; NIST CSF 2.0

教學重點 醫療器材與數位健康系統要在設計期建立威脅模型與安全需求，維護 SBOM、測試韌性，並確保上市後能監測、揭露、修補與更新。

資料外洩應變：出事了怎麼辦

事前準備，決定事後傷害有多大

- 1 **偵測與控制** 盡快發現、隔離，阻止繼續擴大
- 2 **評估影響** 哪些資料、多少人、多敏感
- 3 **通報** 依法通報主管機關與當事人（各國有時限）
- 4 **補救與協助** 協助受影響者（如信用監控）、修補漏洞
- 5 **檢討改善** 根因分析、更新防護與流程

教學重點 外洩不是『會不會』而是『何時』：所以事前要有應變計畫。關鍵是『通報』——GDPR 要求 72 小時內通報主管機關，台灣個資法（2025 新制）也強化外洩通報義務，隱匿不報可能加重責任。誠實、及時地通報並協助受影響者，雖然痛苦，卻遠比被揭發、被重罰、失去信任來得好。事前演練，才不會臨事慌亂。

事件應變：把偵測、回應與復原嵌入日常風險管理

NIST SP 800-61 Rev.3 不再把應變當孤立作業，而是讓 CSF 2.0 六大功能共同降低事件數量與衝擊

持續基礎：GOVERN 治理 | IDENTIFY 盤點風險 | PROTECT 降低事件發生與衝擊



依據：NIST SP 800-61 Rev.3 (2025)；台灣個資法第 12 條 (2025 修正)

教學重點 出事後要同時跑兩條線：技術上偵測、隔離、復原；治理上評估權益影響、通知與通報、保存證據、溝通並把教訓回饋控制。

5

PART 5

數位健康倫理

Emerging Digital Health Ethics

新增・對應：二次利用・公平・治理

數位時代帶來傳統倫理框架沒預料到的新問題。

這一部談這些新課題，並用一個實例把整課串起來。

數位時代的新倫理課題：傳統框架接不住的

大規模、可推論、會學習的資料，帶來新問題

新課題	問題是什麼	回到哪個原則
二次利用	為 A 目的收的資料，能否用於 B?	尊重人、目的限制
演算法偏誤	模型對某些族群不公平 (接 9.5)	正義、公平
公平近用	數位落差讓弱勢被排除 (接 9.6)	正義
推論隱私	從無害資料推出敏感事實	尊重人、隱私
資料所有權	資料是誰的？商業利用該不該分享利益？	尊重人、正義

教學重點 新瓶裝舊酒——問題是新的，原則是舊的：數位健康的新課題（二次利用、AI 偏誤、數位落差、推論隱私、資料所有權）看似前所未見，但都能回到 Belmont 三原則思考。例如『把健康資料賣給廣告商』違反尊重人與目的限制；『AI 對某族群失準』違反正義。原則沒變，只是應用到更複雜、更大規模的情境。

WHO 健康 AI 六項倫理原則

從「模型準不準」擴展到自主、安全、透明、問責、公平與永續，才是完整的健康 AI 治理



依據：WHO, Ethics and governance of artificial intelligence for health (2021)

教學重點 倫理原則必須落地成具體角色、證據與補救：誰核准、驗證哪些族群、何時告知、如何申訴、出錯時誰能停用與負責。

同意的新模式：回應『二次利用』難題

一次性同意不夠，發展出新做法

新的同意模式

- 廣泛同意 Broad consent：同意未來一類研究，而非單一研究（需治理配套）
 - 動態同意 Dynamic consent：數位平台讓當事人隨時查看、調整同意範圍
 - 退出機制 Opt-out：預設納入、可退出（爭議大，需透明）
- 在『可用』與『自主』間找平衡

配套：資料治理

- 光有同意不夠，要有『治理』機制
 - 資料存取委員會：審核誰能用、做什麼
 - 資料信託 Data trust：代當事人管理資料
 - 透明的稽核與問責
- 讓二次利用『有人把關、可被監督』

教學重點 回應二次利用的兩條腿：① 更好的『同意模式』——廣泛同意（同意未來一類研究）、動態同意（隨時可調整）、退出機制，各有優缺。② 更強的『資料治理』——不能只靠一紙同意，還要有資料存取委員會審核每個使用、資料信託代當事人把關、透明稽核。同意賦予正當性，治理提供持續的監督——兩者缺一，二次利用就容易失控。

公平、透明與操縱：AI 時代的倫理紅線

技術越強，越要小心它傷害誰

公平與透明

- 演算法偏誤→對弱勢系統性不利 (接 9.5)
 - 數位落差→工具反而擴大健康不平等 (接 9.6)
 - 黑箱決策→當事人有權知道被如何評斷
 - 要能解釋、可申訴
- 別讓科技加深既有不平等

操縱與雙重用途

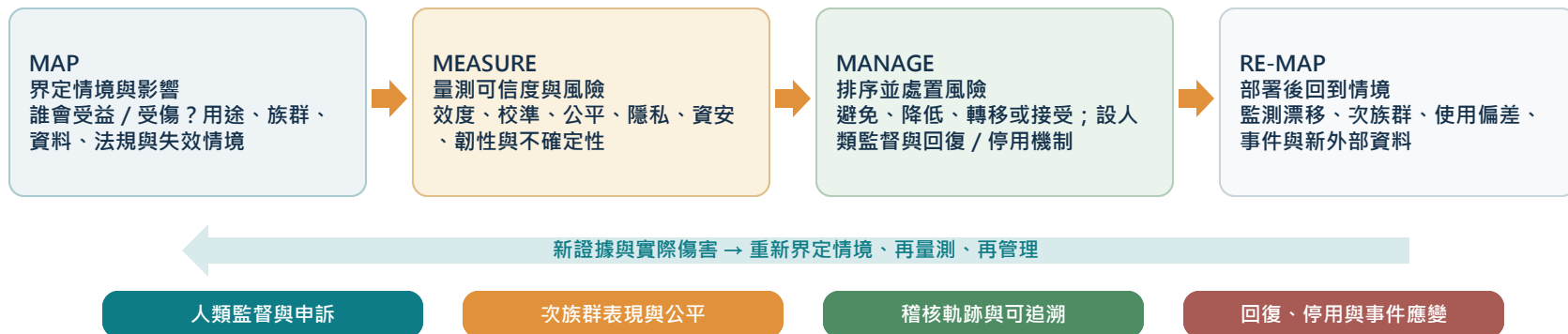
- 暗黑模式：設計誘導人做非本意的事
 - 成癮設計：利用心理弱點衝黏著度
 - 雙重用途：健康資料被用於歧視
(保險、就業)、監控
 - 商業誘因 vs 病人福祉的張力
- 有能力，不代表就該做

教學重點 AI 時代的新紅線：① 公平——確保模型與工具不對弱勢族群系統性不利 (接 9.5 分族群評估、9.6 數位落差)。② 透明——當事人有權知道自己被如何評斷、能申訴。③ 反操縱——別用暗黑模式、成癮設計利用心理弱點。④ 防雙重用途——健康資料絕不能被用於歧視或監控。核心提醒：『技術上做得到』不等於『倫理上該做』。

AI 風險管理：GOVERN、MAP、MEASURE、MANAGE 的持續循環

可信 AI 不是一次性驗證；情境、資料、族群、模型與實際使用一變，就要重新界定、量測與處置風險

GOVERN | 政策、角色、風險容忍、利害關係人、事件與供應鏈責任——貫穿整個 AI 生命週期



依據：NIST AI RMF 1.0 (GOVERN / MAP / MEASURE / MANAGE) ； WHO AI for Health

教學重點 先用 MAP 說清楚使用情境與可能傷害，再用 MEASURE 建立效度、公平、隱私與韌性證據，由 MANAGE 排序處置；GOVERN 貫穿責任與監督。

綜合實例：穿戴式資料研究平台

把 Part 1–4 的倫理把關，一次走完

面向	這個平台怎麼把關	對應
同意	動態同意平台，可隨時調整範圍	尊重人、數位同意
審查	送 IRB；設資料存取委員會	IRB、治理
去識別	假名化 + 專家判定，評再識別風險	Part 3
資安	加密、最小權限、稽核、外洩應變	CIA、Part 4
公平	分族群評估、納入多元使用者	正義、接 9.5/9.6
二次利用	每個新用途重審，不得商業歧視	目的限制、雙重用途

教學重點 看整體：一個負責任的健康資料平台，倫理是『貫穿全程』而非事後補的——用動態同意尊重自主、送 IRB 與設資料存取委員會把關、用假名化 + 專家判定並評估再識別風險、用加密與最小權限守住資安、分族群評估確保公平、每個二次利用都重審且禁止商業歧視。這就是把 Belmont 三原則，落實到數位健康的每一個環節。

用資料與 AI 的『可以』與『不可以』

能力越大，責任越大

✓ 該做的

- 目的限制 + 資料最小化，只拿必要的
- 送 IRB、取得有效同意（或合法去識別）
- 評估再識別風險、用隱私增強技術
- 分族群檢查公平、透明可申訴
- 守資安、備妥外洩應變

✗ 不可以

- 『先蒐集再說』、超出同意範圍他用
 - 把去識別當萬靈丹、忽略再識別
 - 把健康資料賣給廣告/用於歧視
 - 用暗黑模式或成癮設計
 - 出事隱匿不通報
- 做得到 ≠ 該做

教學重點 底線原則：健康資料的力量伴隨重大責任。可以——在同意、最小化、去識別、公平、資安的前提下善用資料造福健康；不可以——超範圍蒐用、假設去識別萬無一失、拿去歧視或操縱、出事隱匿。若用 AI 還要疊加 9.5 的驗證與公平紀律。記住：使用者的信任是健康科技最珍貴的資產，一旦失去就難以挽回。

本課總覽：一頁看完隱私、資安與倫理

正當、安全、可信地使用健康資料

主題	關鍵心法	對應
研究倫理	尊重人、行善、正義三原則	Belmont、IRB
隱私法規	目的限制、最小化；健康屬特種資料	HIPAA/GDPR/個資法
去識別	假名≠匿名；評再識別風險	Safe Harbor、差分隱私
資安	機密、完整、可用；備外洩應變	CIA 三要素
數位倫理	二次利用治理、公平、反操縱	接 9.5/9.6

教學重點 帶走一句話：健康科技的一切——有效的模型、好用的介面、能上市的產品——都建立在『使用者願意把資料託付給你』的信任之上。而這份信任，靠的是正當（倫理與同意）、安全（資安）、可信（透明與公平）地使用資料。這一課是整個單元 9 的良心：有能力用資料，更要有守則守住那份信任。



作業

帶回家作業 Take-home Assignment

An Ethics & Privacy Plan

Part A 觀念題 · Part B 實作題 (附參考答案)

作業目標：能用三原則判斷倫理、規劃同意與去識別、守資安，
並辨識並回應數位健康的新倫理課題。

作業說明與繳交

建議 3–4 頁；重點是判斷與規劃，不是背條文

形式與繳交

- 形式：一份倫理與隱私計畫(PDF/Word)
- 篇幅：Part A 每題 3–5 句；Part B 完整規劃
- 可畫『資料流與把關點』示意
- 獨立完成；可用 AI 協助但需自行核對並揭露
- 繳交期限：兩週後上課前

評分重點

- 三原則與同意/IRB 判斷 (25%)
- 隱私原則與去識別規劃 (25%)
- 再識別風險意識 (15%)
- 資安與外洩應變 (15%)
- 數位倫理新課題辨識 (20%)

情境 (Part B 共用)：你要建一個平台，蒐集使用者穿戴裝置的心率/睡眠資料做心理健康研究。

教學重點 寫作提醒：每個設計都要說『違反或符合哪個原則/法規、你怎麼把關』。老師看的是你能不能把『倫理→隱私→去識別→資安→數位倫理』整套，實際用在一個健康資料平台上，而不只是列一堆技術。

四題觀念題（每題 3–5 句）

用你的話講清楚

A1

用 Belmont 三原則，說明為何『未經同意就拿使用者健康資料做研究』不倫理。

A2

『假名化』和『匿名化』差在哪？為什麼假名資料在法律上仍是個資？

A3

為什麼說『去掉姓名』不等於安全？請用再識別風險說明，並提一個降低風險的做法。

A4

舉一個『數位健康特有』的倫理課題，說明它為何棘手，以及可回到哪個原則思考。

教學重點 提示：A1 想尊重人（自主）/行善/正義；A2 想能不能還原、有無對照表；A3 想生日+性別+郵遞區號、k-匿名；A4 想二次利用/演算法偏誤/數位落差等。

為穿戴式心理健康平台做倫理與隱私規劃

心率/睡眠資料 × 心理健康研究

為這個平台，請完成：

- B1 你會怎麼設計『知情同意』？為什麼傳統一次性同意可能不夠？
- B2 列出兩個你會遵守的隱私原則，並說明具體怎麼做。
- B3 你會怎麼去識別？會如何評估與降低再識別風險？
- B4 列出三項資安防護措施（對應 CIA）。
- B5 指出一個此平台可能的『數位倫理風險』，並說明你的對策。

教學重點 重點：B1 動態/廣泛同意 + 治理；B2 目的限制、最小化；B3 假名化 + 專家判定、評 k-匿名與軌跡獨特性；B4 加密（機密）、稽核與備份（完整/可用）、多因素認證；B5 如推論出心理狀態被誤用、演算法偏誤——對策是治理、公平評估、限制二次利用。

想更深入可以看這些

權威文件與法規

主題	來源
研究倫理	Belmont Report (1979)；赫爾辛基宣言；CIOMS 倫理準則
美國/歐盟	HIPAA 隱私/資安規則、去識別指引；EU GDPR (特種資料、DPIA)
台灣	個人資料保護法；2025 修法與個人資料保護委員會(PDPC)
去識別/隱私技術	HIPAA Safe Harbor/專家判定；k-匿名；差分隱私；聯邦學習
資安	CIA 三要素；NIST/ISO 27001；醫材資安 (接 9.10)
數位倫理	AI 倫理、健康 AI 倫理指引、遠端遙控手術倫理準則

教學重點 這一課『增修單元 7.1 研究倫理』並延伸到數位健康，與整個單元 9 緊密相扣：健康資料接 9.1, AI 公平與聯邦學習接 9.5，數位落差接 9.6，醫材資安接 9.10。真正執行時，務必以最新法規（尤其台灣 PDPC 新制）與貴機構倫理委員會為準——法規會更新，本課提供的是可長久適用的『原則與思考框架』。



資料隱私、資安與數位健康倫理 · Privacy, Security & Digital Ethics

正當 · 安全 · 可信地使用健康資料

信任，是健康科技最珍貴的資產——用得了資料，更要守得住信任

Belmont · HIPAA/GDPR/個資法 · 去識別 · CIA · 二次利用治理 · 公平

案例應用：交班紀錄裡有住民的個資

案例 Q | AI 照護紀錄摘要工具對長照機構交班效率與紀錄品質之影響

①

本單元教了什麼

去識別化方法、再識別風險評估，以及數位健康的新倫理課題。

②

案例怎麼用

- 交班紀錄含住民姓名、床號、診斷與家屬聯絡事項，屬高敏感個資。
- 研究者取得之資料於機構端即完成去識別化，不接觸對照表。
- 人員代號以加鹽雜湊處理；串接完成後刪除雜湊值，改以研究流水號。
- 再識別風險來自小群體：B 機構單位主管僅 1 人，任何分層報表都可能指認到個人。
- AI 工具將紀錄送往院外運算者，須另行評估委外處理之合約與資料落地。

③

產出什麼證據

資料保護影響評估摘要（次頁），連同 IRB 送審文件一併提交。

④

承接關係

上游：承自 9.10 之醫材屬性判定表 | 下游：交棒 9.12，估算這項投資值不值得。

教學重點 去識別化不等於不可識別。本案例 B 機構的單位主管只有 1 人——只要報表分到「機構 × 職類」這一層，這個人就被指認出來了。

示範產物：資料保護影響評估摘要

每一項風險都須對應具體措施與可查核之證據，不得只寫「將妥善保護」

風險	情形	因應措施	查核方式
直接識別	紀錄含住民姓名、床號與診斷	機構端去識別化後始交付；研究者不接觸對照表	資料交付紀錄
再識別（小群體）	B 機構單位主管僅 1 人	分層報表最小人數門檻設為 5；不足者合併呈現	報表產製規則
人員層級可回溯	需以人員代號串接三個資料檔	加鹽雜湊；串接後刪除雜湊值改為流水號	腳本可查核
委外運算	AI 摘要由院外服務運算	評估合約、資料落地與保存期限；必要時改為院內部署	委外合約審查紀錄
存取控管	分析資料集存放位置	院內加密資料夾，僅研究者與指導教授可存取	存取權限清單
保存與銷毀	研究結束後之處理	口試通過後保存 3 年，屆期以不可復原方式刪除	銷毀紀錄表

教學重點 第二列的處理方式值得記住：最小人數門檻設為 5，不足者合併。這是統計揭露控管最基本、也最常被忘記的一條規則。